MODULE 4 · LECTURE 21b

CS 6530 Applied Cryptography

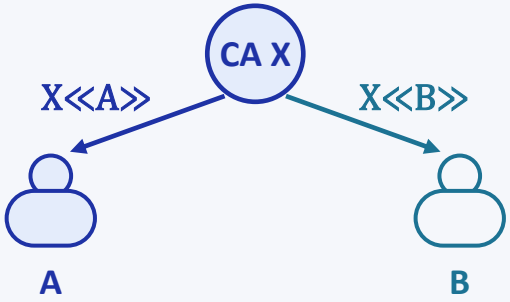
X.509 Certificates and Certificate Validation

Module 4 – Key Management, Certificates and PKI

SCALING CERTIFICATE TRUST

What If A and B Trust Different CAs?

SAME CA

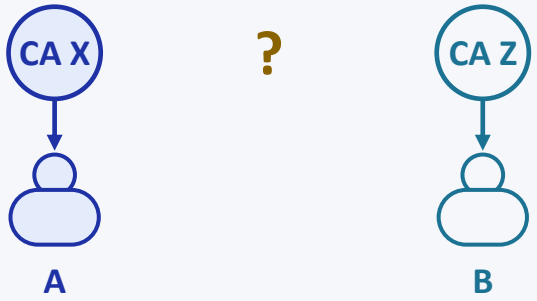


A trusts PK_X →

A can verify X's signature on X≪B≫

X≪A≫ = certificate for A issued/signed by X

DIFFERENT CAs



trusts PK_X

has certificate Z≪B≫

A has no trusted PK_Z. How can it obtain a trusted PK_B?

At scale, every entity cannot simply preconfigure trust in every CA.

? THINK LIKE AN ENGINEER

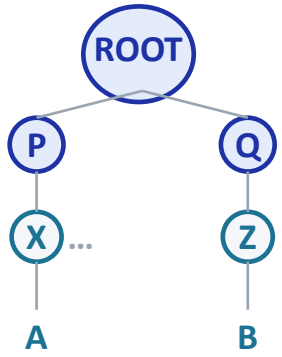
Can certificates themselves form a path from something A already trusts toward B?

When entities rely on different CAs, a trusted certification path is needed to connect them.

CERTIFICATION PATH

A Certificate Chain Is a Path Through the Trust Structure

Simplified hierarchy



Many CAs may exist here.

CERTIFICATION PATH

TRUSTED ROOT / ANCHOR

Higher CA / Trusted Root

Root's key verifies Intermediate's signature

INTERMEDIATE CA

WE2

WE2's key verifies the Leaf's signature

END-ENTITY / LEAF

mail.google.com

TERMINOLOGY

Certificate chain

→ common term for linked certs

Certification path

→ path toward a trust anchor

KEY CONCEPT

Each certificate is verified using its issuer's public key

Leaf ← verified using WE2's key

WE2 ← verified using its issuer's key

…until an established trust anchor is reached.

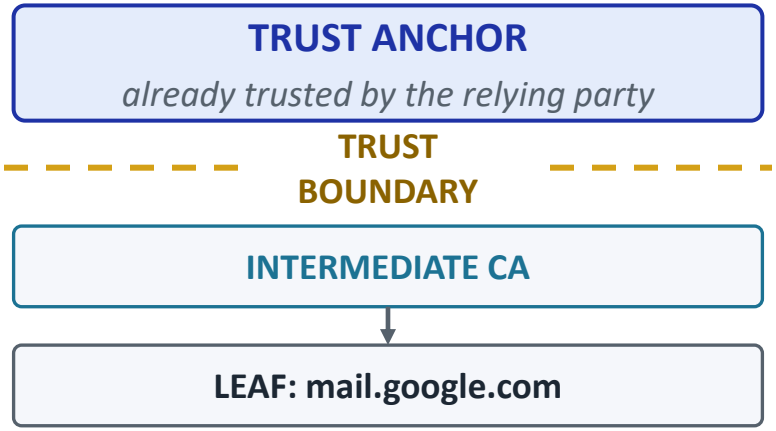
? THINK LIKE AN ENGINEER

If every signature along the path verifies, where does the original trust come from?

Certificate validation follows a certification path from the target certificate toward an established trust anchor.

TRUST ANCHORS

Where Does the Trust Path Stop?



DEFINITION

TRUST ANCHOR: A trusted CA identity/key used to start certification-path validation.

e.g., OS, browser, or app trust configuration

***Trust boundary**: the point separating what the relying party already trusts by configuration from what must be validated using that trust.*

A certificate chain cannot create trust from nothing.

The validated path must terminate at something the relying party already trusts.

SELF-SIGNED ≠ TRUSTED

Many root CA certificates are self-signed.

Self-signature ≠ automatic trust.

? QUICK CHECK

A valid self-signed cert — must your browser trust it?

No.

? THINK LIKE AN ENGINEER

If trust begins at an anchor, how can A traverse a larger CA hierarchy to reach B?

A certification path is trusted because it terminates at an independently trusted anchor—not merely because its signatures verify.

TRAVERSING A CA HIERARCHY

How Does A Obtain B's Trusted Public Key?

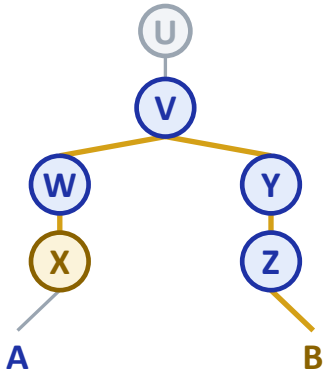
$X\ll Y\gg$ = certificate for Y issued/signed by X

FORWARD CERTIFICATE (for X)

Certificate of X generated by another CA, e.g. $W\ll X\gg$

REVERSE CERTIFICATE (at X)

Certificate generated by X certifying another CA, e.g. $X\ll W\gg$



A already trusts PK_X (gold path).

A trusts PK_X — how can it obtain a trusted PK_B?

$$X\ll W\gg \rightarrow W\ll V\gg \rightarrow V\ll Y\gg \rightarrow Y\ll Z\gg \rightarrow Z\ll B\gg$$

Trust $PK_X \rightarrow PK_W \rightarrow PK_V \rightarrow PK_Y \rightarrow PK_Z \rightarrow PK_B$

ONE STEP: trust PK_X → verify $X\ll W\gg$ → obtain trusted PK_W → repeat

Reverse (B→A): $Z\ll Y\gg \rightarrow Y\ll V\gg \rightarrow V\ll W\gg \rightarrow W\ll X\gg \rightarrow X\ll A\gg$

? THINK LIKE AN ENGINEER

What happens if one certificate in this path is invalid, expired, revoked, or violates its constraints?

INSIGHT

A complex CA hierarchy is still the same mechanism: trust is extended one verified certificate at a time.

Trust propagates along a certification path: each already-trusted CA public key authenticates the next public key toward the target.

SELF-SIGNED CERTIFICATES

Can I Sign My Own Certificate?

mail.google.com

Subject: mail.google.com
Issuer: WE2
Signed by WE2's private key ↓
WE2's public key verifies it →

Different Subject and Issuer

My Lab CA

Subject: My Lab CA
Issuer: My Lab CA
Signed by its own private key ↓
Its own public key verifies it →

Subject = Issuer

Signed by the private key matching its own public key.

Can the self-signature be valid? **YES**

Does that make it trusted? **NO**

Signature validity ≠ Trust

ROOT CA
Commonly self-signed.

ENTERPRISE PKI
Own trust anchor.

DEV / LAB
Trust set in-house.

MyUniversityLabCA → self-signed root → installed in lab trust store → anchors paths

Self-signing does not create trust. Trust comes from independently provisioning it as a trust anchor.

? THINK LIKE AN ENGINEER

What if a certificate should no longer be accepted before its notAfter date?

A self-signature can be cryptographically valid; trust requires independent acceptance as a trust anchor.

CERTIFICATE REVOCATION

A Certificate May Need to Be Rejected Before It Expires

20 Sep 2026 — KEY COMPROMISED

NOT YET VALID	VALID	SHOULD NOT BE ACCEPTED	EXPIRED

10 Aug 2026 — notBefore **2 Nov 2026 — notAfter**

Nominal validity remains — but continued acceptance may no longer be appropriate.

*Should relying parties simply wait until 2 Nov? **NO.***

Key compromise · loss of authorization · status change · CA-key compromise

CRL

Certificate Revocation List

CA publishes a signed list of revoked certificates.

Revoked Serial Numbers (example):
1027, 1942, 3105 → Revoked

OCSP

Online Certificate Status Protocol

Relying Party → status request → OCSP Responder

Response:
good | revoked | unknown

Validity asks: is the validation time within notBefore–notAfter?

Status asks: has the certificate become unacceptable before expiry?

Relying Party: The entity that receives/uses a certificate and must decide whether to rely upon the identity–public-key binding asserted by that certificate.

? THINK LIKE AN ENGINEER

What checks must succeed before a relying party accepts a certificate?

Revocation provides a mechanism for certificates to become unacceptable before their scheduled expiry.

CERTIFICATE VALIDATION

What Must Be Checked Before We Accept a Certificate?

Conceptual validation model — not the exact implementation order of browser or X.509 path-validation algorithms.

TARGET CERTIFICATE: mail.google.com

1 PATH & TRUST
Path to an accepted trust anchor?

2 SIGNATURES
Do required signatures verify?

3 TIME
notBefore ≤ time ≤ notAfter?

4 STATUS
Certificate status acceptable (e.g., CRL / OCSP)?

5 IDENTITY
Hostname matches SAN?

6 USAGE & CONSTRAINTS
Check applicable usage constraints (e.g., KU/EKU)

ACCEPT FOR THIS PURPOSE

Signature verification is necessary — but not sufficient.

A valid signature cannot compensate for: Wrong identity · Expired · Revoked · Wrong usage · Untrusted path

? THINK LIKE AN ENGINEER

Can you now decide whether a browser should accept different certificates?

Certificate acceptance requires path/trust, signatures, time, status, identity, and usage/constraints to be valid for the intended purpose

CLASSROOM VALIDATION CHALLENGE

You Are the Browser — Would You Accept This Certificate?

User visits https://shop.example.com

For each case, assume all validation checks pass except the condition explicitly stated.

CASE A:

SAN includes shop.example.com; date 17 Sep 2026; valid dates; trusted path; TLS server use permitted

ACCEPT : all required checks pass

CASE B:

SAN: www.example.com, example.com

REJECT : identity check fails

CASE C:

Validation date: 17 Sep 2026; notAfter: 16 Sep 2026

REJECT : time check fails (expired)

CASE D:

Certificate chain cannot be built to any trust anchor accepted by the browser

REJECT : path/trust check fails

CASE E:

EKU: Code Signing; requested use: TLS server authentication

REJECT FOR THIS PURPOSE : usage constraint fails

CASE F:

Validation date: 17 Sep 2026; notAfter: 21 Sep 2026; Serial Number present in CRL

REJECT : certificate is revoked

No single certificate field says "TRUST THIS CERTIFICATE."

Acceptance results from the required validation checks plus an independently established trust anchor.

? THINK LIKE AN ENGINEER

Who issues, renews, revokes and manages certificates and trust relationships at scale?

Certificate validation decides whether a certificate is acceptable for a particular identity, purpose and trust context.

Certificate Purpose and File Format Are Different Things

X.509 CERTIFICATE

Identity information · Public key · Issuer · Validity · Extensions · Signature

PURPOSE / ROLE

TLS Server / Client Certificate

Authenticates a server or a client

CA Certificate

Authorized to certify other certificates

Code-Signing Certificate

Authenticates signed software / code

Email / S/MIME Certificate

Used for email-security purposes

REPRESENTATION / CONTAINER

DER

Binary encoding — e.g. 30 82 05 …

PEM

Base64 text with BEGIN/END delimiters

.pem .crt .cer

Extension alone ≠ certificate purpose

PKCS #12 (.p12 / .pfx) — CONTAINER

Bundles a key + certificate chain; may be password-protected

PURPOSE ≠ REPRESENTATION

"TLS server" → use "PEM / DER" → representation "PKCS #12" → container

Can the filename alone tell us this is a TLS-server certificate?

server.pem → NO — inspect the certificate's contents / extensions and context.

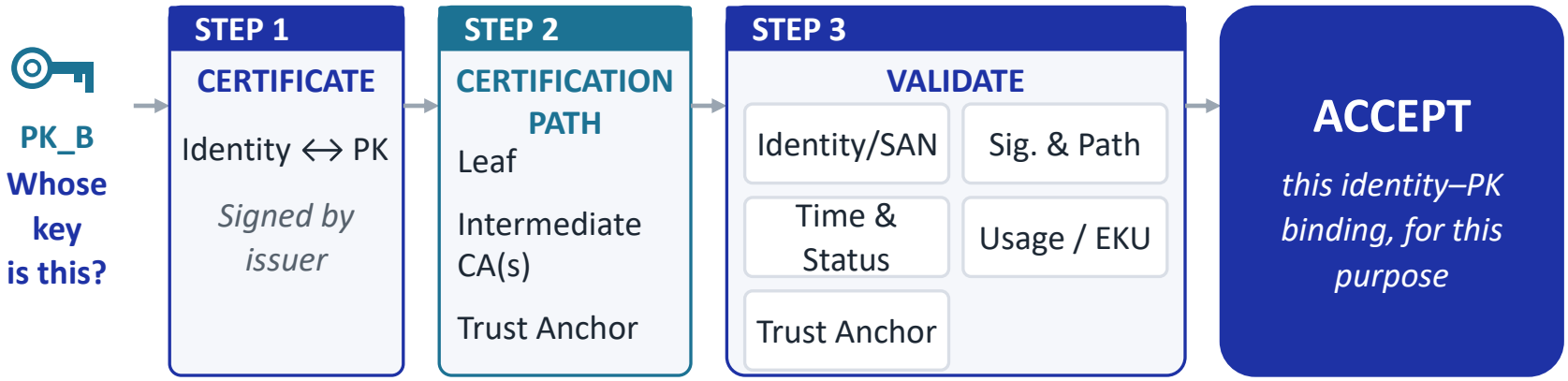
? THINK LIKE AN ENGINEER

Across everything we studied today, when should we accept an identity–public-key binding?

Certificate purpose, certificate representation and key/certificate containers are distinct concepts.

CONSOLIDATION

When Do We Accept an Identity–Public Key Binding?



STUDENT RECALL — ASK THE CLASS

1. What does it bind?	Identity ↔ Public key
2. Who signs it?	Issuer's digital signature
3. How does trust cross CAs?	Certification path
4. Where does it stop?	An independently trusted anchor
5. Is a valid signature enough?	No — other checks must also succeed

Certificate ≠ Trust

Certificate → signed assertion

Validation + trusted anchor → decision to accept, for this use

NEXT → PKI & OPERATIONAL KEY MANAGEMENT

Who issues, renews, revokes and manages certificates at scale?

X.509 provides a verifiable identity–public-key binding; validation determines whether that binding is acceptable for the intended use.

REFERENCES

References & Further Reading

PRIMARY TEXTBOOK REFERENCE

William Stallings

Cryptography and Network Security

§15.4 — X.509 Certificates

X.509 certificate structure · certificate use · CA hierarchy · certification paths

SUPPORTING TEXTBOOK REFERENCE

Christof Paar & Jan Pelzl

Understanding Cryptography, 2nd ed.

§14.4.2 — Certificates

§14.5 — PKIs and CAs

especially:

§14.5.1 — Certificate Chains

§14.5.2 — Certificate Revocation

STANDARDS / AUTHORITATIVE REFERENCES

ITU-T Recommendation X.509 / ISO/IEC 9594-8 — Public-key and attribute certificate frameworks

RFC 5280 — Internet X.509 PKI Certificate and CRL Profile

RFC 6960 — X.509 Internet PKI Online Certificate Status Protocol (OCSP)

Real certificates examined in class: ***Google Mail · IIT Madras · Amazon India***

(Examples/demonstrations, not normative references.)

Use the standards for normative detail; use Stallings and Paar & Pelzl for the conceptual and textbook treatment.